INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — Makine Sürümü · Luna 1300 Pro Fırça Zımpara

İlk dört haftanın laboratuvarları, kendi seçtiğim tek bir makine — Baromak LUNA 1300 PRO otomatik fırça zımpara makinesi — üzerinde işlendi.

LAB 1 · Safety Architecture	1. Hafta	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	2. Hafta	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	3. Hafta	Çıktı: Risk Register
LAB 4 · Secure Remote Access	4. Hafta	Çıktı: Secure Architecture

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Makinenin emniyet donanımına dair bilgiler üreticinin yayımladığı bilgilerden değil, benim varsayımlarımdan gelmektedir (bkz. makine sayfası).

HAZIRLAYAN
Muhammed Cemil Çaka

MAKİNE TANITIMI · föylerin üzerinde çalıştığı makine

Baromak LUNA 1300 PRO

Otomatik Fırça Zımpara

Bursa'daki Baromak firmasının ürettiği otomatik fırça zımpara makinesi. Masif, MDF ve kontrplaktan yapılmış kapı ve kapakların, özellikle CNC ile işlenmiş fugalı, rustik ve çıtalı modellerin kaba ve astar zımparasında kullanılıyor. Parça konveyörün üstünde makinenin içinden geçiyor, üstteki 6 fırça istasyonu zımparalıyor, çıkıştaki fırçalı temizleme istasyonu da tozunu alıp parçayı boyaya hazır hâle getiriyor.

Teknik bilgiler (ilandan)

Toplam ağırlık	3.730 kg
Ölçüler	1970 × 4580 × 2300 mm
Toplam güç	18 kW *
Voltaj	380 V, 3 faz
Ürün genişliği	10 – 1300 mm
Ürün uzunluğu	min. 400 mm, max. sınırsız
Ürün kalınlığı	10 – 160 mm *
Konveyör hızı	max. 20 m/dk

** İlanda toplam güç 18 kW, min. kalınlık 10 mm yazıyor. Baromak'ın kendi sayfasındaki teknik tabloda ise 14,5 kW ve 3 mm görünüyor. Hangisinin güncel olduğundan emin olamadım, föylerde ilandaki değerleri kullandım.*

Üreticinin sayfasından öğrendiklerim

- 6 adet birbirinden bağımsız, çift yönlü çalışan, osilasyonlu fırça istasyonu
- Dahili osilasyonlu cumba (kenar) zımpara istasyonu
- Her istasyonda 0,10 mm hassasiyetle baskı ayarı
- 10 inç dokunmatik panel (HMI)
- Reçete hafızası: her kapak modeli için ayarları isim verip kaydetme, tek tuşla çağırma
- **Uzaktan bağlantı:** üretici makineye 7/24 bağlanıp arıza tespiti ve eğitim yapabiliyor
- Lineer kızaklar için otomatik yağlama
- Bakım, temizlik ve zımpara değişimi için çekmeceli istasyonlar
- Her istasyonda, makine çalışırken zımparayı temizleyen hava üfleme sistemi
- Çıkışta fırçalı temizleme istasyonu ve 1 m'lik dahili çıkış konveyörü

Varsayımlarım

Ne ilanda ne de üreticinin sayfasında makinenin emniyet donanımı (kaç acil stop var, kapaklarda kilit var mı, safety PLC mi emniyet rölesi mi kullanılıyor) yazıyor. Bu yüzden föyleri doldururken bu sınıf bir makinede olması gereken yapıyı varsaydım:

- Makine üstünde, girişte ve çıkışta acil stop butonları
- İstasyon çekmecelerinde ve bakım kapaklarında kilitli emniyet switchleri
- Bunları izleyen bir safety PLC (emniyet rölesi de olabilir)
- Fırça, osilasyon ve konveyör motorlarını süren inverterlerde STO girişi
- Normal kontrol tarafında bir PLC ve 10 inç HMI, üreticinin uzaktan bağlantısı da bu tarafa bir modem/router üzerinden geliyor

Gerçek makineyi görme imkânım olursa bu kısmı düzelteceğim.

Bu makineyi seçmemin bir sebebi de uzaktan bağlantı özelliğinin olması. Föylerdeki siber güvenlik kısmını havada bırakmadan gerçek bir bağlantı noktası üzerinden düşünebildim.

Kaynaklar: İlan — https://twm.com.tr/tr/ilan/luna-1300-pro-firca-zimpara-makinesi
Üretici sayfası — https://baromak.com.tr/urun-detay.html?id=luna-1300-pro

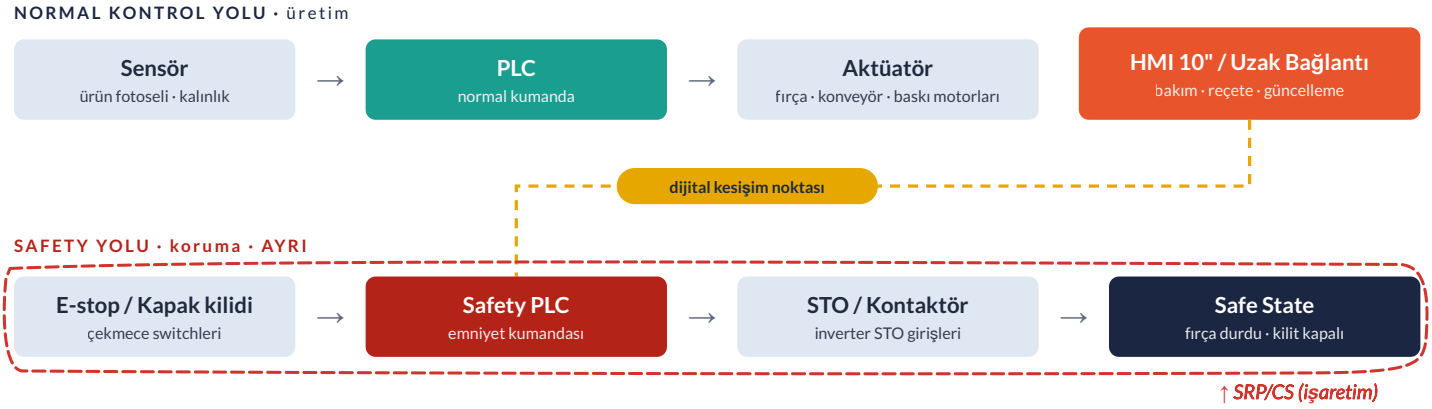
LABORATUVAR 1 · MAKİNE SÜRÜMÜ · Luna 1300 Pro Fırça Zımpara

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad	Muhammed Cemil Çaka	Grup		Tarih	1. Hafta

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve **ayrı bir safety yolunda** yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, **dijital bir konfigürasyona** bağlıdır.



Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

Bence en büyük tehlike dönen fırça istasyonları. 6 istasyon var ve hepsi hem dönüyor hem de osilasyon yapıyor, yani sağa sola gidip geliyor. El, eldiven, bol kıyafet ya da uzun saç fırçaya kaptırılırsa sarılma olur, bu da kol kaybına kadar gidebilir. İkinci tehlike konveyörün giriş ağzı: parçayı elle sürerken parmak bant ile parçanın arasına girip içeri çekilebilir. Bakım sırasında en sinsi olanı da şu: motor durdurulsa bile fırçalar ağır olduğu için bir süre ataletle dönmeye devam ediyor, çekmeceli istasyonu erken açan kişi elini dönen fırçaya sokmuş oluyor. Bunların dışında kısa/ince parçanın geri fırlaması, ahşap tozu (hem solunum hem toz yangını), istasyonlardaki basınçlı hava üflemesi ve 380 V elektrik var.

2 Safety function (emniyet fonksiyonu) hangisidir?

Seçtiğim fonksiyon: **istasyon çekmecesi / bakım kapağı için kilitli koruyucu.** Kapak kapalı ve kilitli değilse fırça, osilasyon ve konveyör motorları çalışamaz. Kapağı açma isteği gelince motorlar durdurulur ve fırçalar tamamen durmadan kilit açılmaz. Acil stop ve konveyör girişindeki el koruması da birer emniyet fonksiyonu ama bu föyde kapak kilidini ana fonksiyon olarak aldım, çünkü zımpara değişimi ve temizlik yüzünden insanın her gün en çok yaklaştığı yer orası.

3 Safety-related control system nerede? Şemada işaretleyin.

Şemada kırmızı kesikli çizgiyle çerçeveledim. Giriş tarafı kapak/çekmece kilit switchleri ve acil stoplar, mantık kısmı safety PLC, çıkış tarafı da inverterlerin STO girişleri ile ana kontaktörler. Yani alttaki satırın tamamı SRP/CS; üstteki PLC ve HMI bunun dışında kalıyor.

4 Normal PLC ile Safety PLC farkı nedir?

Normal PLC üretimi yönetiyor: konveyör hızı, her istasyonun baskı ayarı, osilasyon, reçeteler, otomatik yağlama vs. HMI'dan ve uzaktan bağlantıdan sürekli komut alıyor, programı da sık değişebiliyor. Safety PLC'nin ise tek işi insanı korumak. Girişleri çift kanallı okuyor, kendini sürekli test ediyor, bir hata görürse durdurma tarafına geçiyor ve PL/SIL sertifikası var. Programı parola ve checksum ile kilitli, üretim ayarlarıyla hiç işi yok. Kısacası normal PLC bozulsa ya da ele geçirilse bile safety PLC motorları kesebilmeli.

Safety Architecture *(devam)*

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

Her emniyet fonksiyonunun aynı derecede güvenilir olması gerekmiyor, ne kadar güvenilir olacağını risk belirliyor. PLr de bunun ölçüsü. ISO 13849-1'deki risk grafiğiyle denedim: şiddet **S2** (fırçaya kol kaptırmak geri dönüşü olmayan bir yaralanma), sıklık **F2** (zımpara değişimi ve temizlik her vardiya yapılıyor), kaçınma olasılığı **P1** (fırça görünüyor, yavaşladığı fark ediliyor). Buradan **PLr d** çıktı. Ataletle dönen fırçayı fark etmek zor diye P2 dersek PLr e oluyor; açıkçası P1 ile P2 arasında kaldım. Fonksiyon için önemli çünkü PLr d demek çift kanal, diagnostik ve arıza toleransı demek; tek bir switch ya da tek kontaktörle bu iş çözülemez.

6 Safe state (güvenli durum) nedir?

Fırça motorları, osilasyon ve konveyörün enerjisiz ve gerçekten durmuş olması (sıfır hız), inverterlerde STO'nun aktif olması. Kapak kilidi fırçalar durana kadar kapalı kalıyor, istasyonlardaki hava üflemesi kesiliyor. Kapak kapatılıp reset'e basılmadan makine kendi kendine tekrar kalkmıyor. Burada dikkat ettiğim nokta şu: motora "dur" komutunun gitmiş olması safe state değil, fırçanın fiilen durmuş olması safe state.

7 Safety function hangi dijital bağımlılıklara sahip?

- Safety PLC programı ve parametreleri (kilit açma gecikmesi veya durma izleme ayarı, giriş filtre süreleri)
- Safety PLC firmware'i ve programın checksum'ı
- İnverterlerdeki STO ayarları ile fren / duruş rampası parametreleri (fırçanın kaç saniyede duracağını bunlar belirliyor)
- Mühendislik yazılımı ve onun kurulu olduğu servis laptopu
- Dolaylı olarak HMI'dan girilen reçete değerleri ve uzaktan bağlantı modemi

Yani fonksiyon kâğıt üstünde "donanım" gibi dursa da aslında birkaç dosyaya ve parametreye bağlı.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

Bence en zayıf nokta üreticinin 7/24 uzaktan bağlantısı. Bu bağlantıyı ele geçiren biri HMI/PLC'ye, oradan da inverterlere ulaşabilir. Mesela fırça motorunun duruş rampasını 5 saniyeden 40 saniyeye çıkarırsa ve kapak kilidi sadece sabit bir süre bekleyip açılıyorsa, bakımcı çekmeceyi açtığında fırça hâlâ dönüyor olur. Safety programına kimse dokunmadan fonksiyon boşa çıkmış olur. İkinci nokta servis laptopu / USB (safety programı veya gecikme süresi değiştirilebilir), üçüncüsü parolasız HMI. Şemadaki sarı "dijital kesişim noktası" tam olarak bu.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad	Muhammed Cemil Çaka	Grup		Tarih	2. Hafta

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

PLC · HMI (10" dokunmatik) · İnverter / servo sürücüler · **Safety PLC** · Üretim takip PC'si (SCADA istemcisi) · Mühendislik / servis laptopu · Uzak servis erişimi (Baromak modemi) · Toz emiş panosu · Ofis ağı (ERP/e-posta)

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Beş bölgeye ayırdım:

- **Z1 Emniyet:** Safety PLC, acil stoplar, kapak kilit switchleri, STO hatları. Ağa hiç çıkmasın istedim.
- **Z2 Makine kontrol:** PLC, 10" HMI, inverterler ve servo sürücüler. Hepsi makinenin kendi panosunda, aynı kritiklikte.
- **Z3 Fabrika / üretim:** Üretim takip PC'si, mühendislik laptopu (bağlı değilken burada), toz emiş panosu.
- **Z4 Uzak erişim DMZ:** Baromak'ın bağlandığı VPN ucu ve jump server. Dışarıdan gelen herkes önce buraya düşüyor.
- **Z5 Kurumsal:** Ofis ağı, ERP, e-posta.

HMI'yı ayrı bölge yapmayı düşündüm ama PLC ile aynı panoda ve sürekli onunla konuşuyor, ayırınca bir şey kazanmıyoruz gibi geldi.

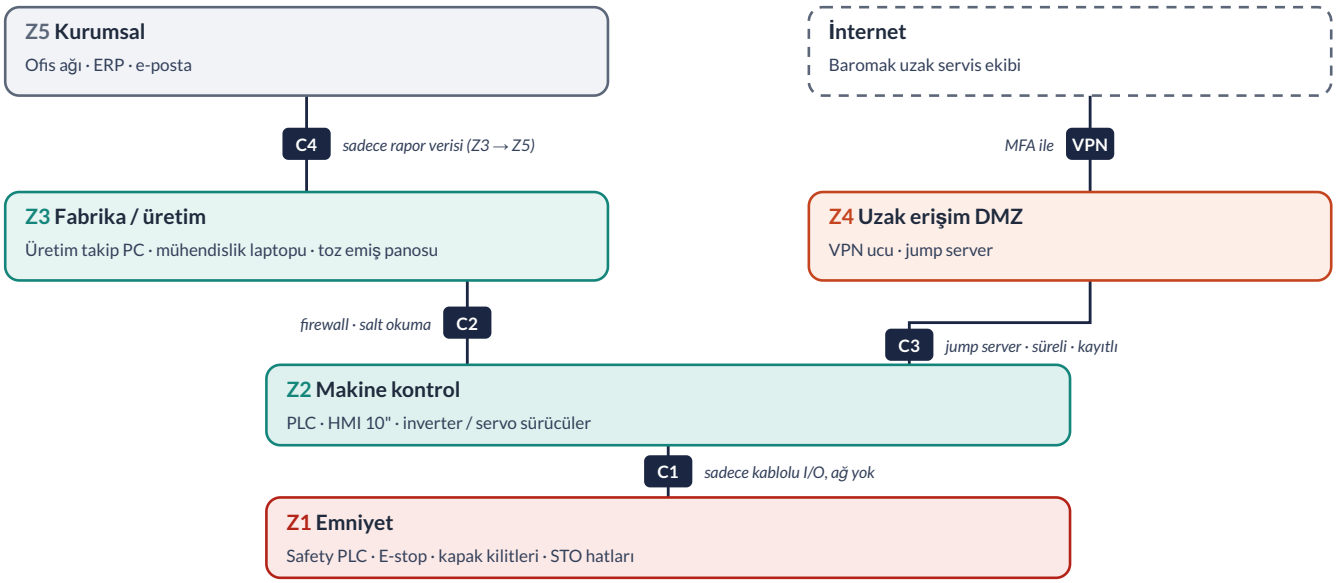
2. Safety PLC'yi hangi bölgeye koydunuz — neden?

Kendi bölgesine (Z1) koydum, PLC ile aynı yere koymadım. Kritikliği diğerlerinden yüksek: o bozulursa doğrudan insan yaralanıyor. PLC ile arasında sadece kablolu I/O olsun; PLC emniyetin durumunu okuyabilsin ama ona yazamasın. Safety programı da ağ üzerinden değil, sadece makinenin başında ve anahtarla değiştirilebilsin.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

- **C1 (Z2 ↔ Z1):** Sadece kablolu I/O, ağ bağlantısı yok. PLC emniyet tarafına komut gönderemez.
- **C2 (Z3 ↔ Z2):** Firewall. Üretim takip PC'si sadece okur (adet, alarm, çalışma süresi); reçete/parametre yazma kapalı. Laptop ancak bakım şefinin izniyle bağlanır.
- **C3 (Z4 ↔ Z2):** Uzaktan bakım geçişi. Jump server üzerinden, sadece HMI/PLC servis portuna, zaman sınırlı ve kayıtlı (Görev B).
- **C4 (Z5 ↔ Z3):** Ofisten makineye doğrudan geçiş yok, sadece rapor verisi Z3'ten Z5'e çıkar.

Zone / Conduit diyagramım



Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server.** Baromak teknisyeni HMI'ya direkt bağlanmasın, önce bizim kontrolümüzdeki ara sunucuya gelsin.
Tünel?	Açık / VPN	**VPN.** Port açıp HMI'yı internete göstermek olmaz.
Kimlik?	Parola / MFA	**MFA.** Parola tek başına çalınırsa her şey biter, ikinci faktör şart.
Hesap?	Paylaşılan / Kişisel	**Kişisel.** Her teknisyenin kendi hesabı olsun, "servis / 1234" gibi ortak hesap kalmasın. Kim ne yaptı belli olsun.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı.** Olay olursa kanıt olur, parametre değişikliklerini de sonradan kontrol ederiz.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı.** Arıza olunca bakım şefi açar, birkaç saat sonra kendiliğinden kapanır. Üretici "7/24 bağlanıyoruz" diyor; servis için güzel ama bizim için 7/24 açık kapı demek.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad: Muhammed Cemil Çaka | Grup: | Tarih: 3. Hafta

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Dış saldırgan (ele geçirilmiş ortak servis parolası) → üreticinin 7/24 açık uzaktan bağlantısı → HMI/PLC üzerinden fırça inverterinin duruş rampasını uzatır → kapak kilidi sabit süre bekleyip açılır → bakımcı çekmeceyi açtığında fırça hâlâ dönüyor, **el/kol fırçaya kaptırılır**	2	3	3	18 · Kritik	1
Fidye yazılımı (ofiste açılan e-posta eki) → ofis ile makine ağı ayrı değil → HMI kilitlenir, kayıtlı reçeteler kaybolur → operatörler baskı ayarını tahminen elle girer, fazla baskı verilir → ince parça sıkışıp **geri fırlar**, operatöre çarpar; aşırı sürtünmeden **toz tutuşabilir**	2	2	2	8 · Orta	3
Zararlı yazılımlı servis laptopu / USB → mühendislik yazılımı → Safety PLC'de kilit gecikmesi kısaltılır veya bir kapak girişi köprülenir → koruyucu açıkken makine çalışabilir → **dönen fırçaya erişim, ağır yaralanma**	1	3	1	3 · Düşük	2 S=3 kuralı

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

L: olasılık · S: şiddet · E: maruziyet

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   Birinci senaryo (uzaktan rampa değişikliği): bağlantı zaten var ve sürekli açık, sonucu kol kaybı ve bakımcı o çekmeceyi her vardiya açıyor.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Var, 3. senaryo. Skoru 3 (düşük) ama S=3 olduğu için öncelikte 2. sıraya aldım. Risk register'da bu satıra kırmızı "S=3" etiketi koyarım, her revizyonda ilk bakılan satır olur. Ayrıca safety programının checksum'ı devreye almada not edilsin ve periyodik bakım formunda "checksum aynı mı?" kontrolü olsun; bu kontrol yapılmadan satır kapanmasın.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Not: 2. senaryoyu ilk yazdığımda "reçeteler şifrelendi" diye bitiriyordum. Altın kurala göre bir adım daha ileri götürüp hattaki operatöre ne olacağını yazdım.

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad	Muhammed Cemil Çaka	Grup		Tarih	4. Hafta

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

Baromak servisi
↓
İnternet
↓
Uzak bağlantı modemi (HMI'ya bağlı)
↓
HMI + PLC + inverterler

- ✗ Bağlantı 7/24 açık
- ✗ Ortak servis kullanıcısı ve parolası
- ✗ MFA yok
- ✗ Kayıt yok, kim neyi değiştirdi bilinmiyor
- ✗ Makine ağı ofis ağıyla aynı (düz ağ)

Gerçek kurulumu görmedim, ilandaki "uzaktan bağlantı" bilgisine göre tipik hâlini çizdim.

HEDEF (beş ilkeyle yeniden tasarlayın)

Baromak teknisyeni
↓
VPN + MFA
↓
Jump server · DMZ (kişisel hesap, oturum kaydı)
↓
Firewall (sadece servis portu)
↓
HMI + PLC (Z2)

- ✓ **Ara nokta:** jump server, makineye direkt bağlantı yok
- ✓ **VPN:** HMI internete açık değil
- ✓ **MFA:** her girişte ikinci faktör
- ✓ **Kişisel hesap + kayıt:** her oturum kaydediliyor
- ✓ **Varsayılan kapalı:** bakım şefi açar, 2 saat sonra kendisi kapanır

Safety PLC (Z1) bu yoldan hiç görünmüyor, ona uzaktan erişim yok.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

Mevcut hâliyle evet, etkilenebilir. Kapak kilidi fırçanın gerçekten durduğuna değil sabit bir süreye bakıyorsa ve fırçanın kaç saniyede duracağı inverterdeki parametreye bağlıysa, saldırgan safety PLC'ye hiç dokunmadan rampayı uzatıp fonksiyonu boşa çıkarabilir (Lab 3, 1. senaryo). Emniyet fonksiyonu kontrol sisteminden gerçekten bağımsız olsaydı saldırgan üretimi durdurabilir, kaliteyi bozabilir, makineyi kilitleyebilirdi ama dönen fırçaya giden kapağı açtıramazdı. Yani erişim güvenliği girişi zorlaştırıyor ama insanı asıl koruyan ikinci katman.

2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

- Fırça istasyonlarına erişim sağlayan koruyucuların kilidi, tüm tehlikeli hareketlerin (fırça, osilasyon, konveyör) gerçekten durduğu emniyet fonksiyonu tarafından doğrulanmadan açılmamalıdır.
- Bu doğrulama PLC, HMI, inverter parametreleri ve uzak erişim üzerinden yapılan hiçbir değişiklikten etkilenmemelidir.
- Emniyet fonksiyonunun parametreleri ağ üzerinden değiştirilememeli; değişiklik sadece yetkili kişi tarafından makinenin başında yapılmalı ve kayıt altına alınmalıdır.
- Normal kontrol sistemi arızalanırsa veya iletişim koparsa makine güvenli duruma geçmelidir. Hedef: PLr d.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.